

CZECH UNIVERSITY OF LIFE SCIENCES

Faculty of Economics and Management

Department of Informatics



IS Security semester project

Analysis of SSL Implementation on selected websites

Submitted to Prof. Ing. Martin Havránek, Ph.D.

Prepared By:

1:Munashe Clever Vukomba

April 2026

Table of Contents

Page

1.	Introduction to SSL Lab.....	4
2.	City of Bulawayo	4
2.1	Overall Rating.....	5
2.2	Certificate.....	6
2.3	Configuration	9
3.	Winsomemadeevents	13
3.1	Overall rating	13
3.2	Certificate.....	14
3.3	Configuration.....	16

List of Figure	Page
Figure 1. Overall rating of www.citybyo.co.zw.....	5
Figure 2. Certificate of www.citybyo.co.zw	6

Figure 3. Configuration of www.citybyo.co.zw	9
Figure 4. Overall rating of www.winsomemadeevents.co.zw	13
Figure 5 . Certificate of www.winsomemadeevents.co.zw	14
Figure 6.Configuration of www.winsomemadeevents.co.zw	16

1. Introduction to SSL Lab

SSL Labs (Secure Sockets Layer) is a non-commercial research effort operated by **Qualys** and led by Ivan Ristić. While SSL is a cryptographic protocol designed to secure communication over networks, SSL Labs goes beyond basic definitions—it provides a collection of documents, tools, and analyses focused on understanding and improving SSL/TLS deployments. The platform allows users to test SSL/TLS connections, assess certificate security, and identify configuration vulnerabilities, making it an essential resource for website administrators aiming to maintain secure, up-to-date SSL/TLS configurations. In this project, SSL Lab implementation is analyzed by selecting two websites, as follows:

2. Bulawayo Municipal City Council

<https://www.citybyo.co.zw/>

2.1 Overall Rating

The overall rating provided by Qualys SSL Labs represents a comprehensive assessment of the security posture of a website's SSL/TLS configuration. This rating aggregates multiple technical criteria into a single grade, offering a high-level indicator of how securely data is transmitted between clients and the server. The evaluation considers several key dimensions, including supported protocol versions (e.g., TLS 1.2 vs TLS 1.3), the strength and configuration of cipher suites, the robustness of the key exchange mechanism, certificate validity and chain integrity, and the presence of known vulnerabilities or misconfigurations.

SSL Report: **www.citybyo.co.zw** (41.79.191.246)

Assessed on: Sat, 25 Apr 2026 10:27:22 UTC | [Hide](#) | [Clear cache](#)

[Scan Another](#)

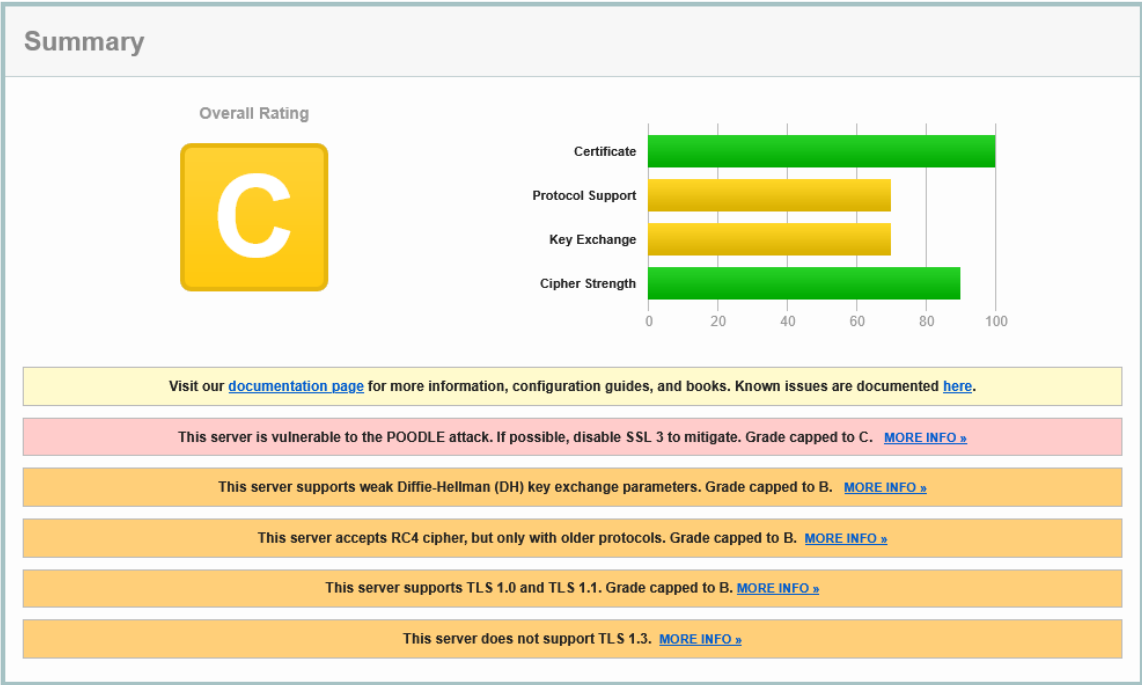


Figure 1. Overall rating of citybyo.co.zw

In this project, the SSL/TLS configuration of City Of Bulawayo’s website (www.citybyo.co.zw) was analyzed using this rating methodology. The resulting grade of **B** reflects a configuration that is generally functional and provides a baseline level of secure communication, but does not fully align with current best practices in transport layer security.

A detailed interpretation of this rating reveals several potential areas for improvement. These may include continued support for older or less secure protocol versions (such as TLS 1.0 or 1.1), the presence of weaker cipher suites that do not offer optimal encryption strength, or suboptimal certificate configurations such as incomplete certificate chains or lack of advanced features like OCSP stapling. Additionally, the configuration may not fully leverage modern security enhancements such as forward secrecy or the exclusive use of strong elliptic curve cryptography.

2.2 Certificate

Certificate #1: RSA 2048 bits (SHA256withRSA)



Server Key and Certificate #1

Subject	*.citybyo.co.zw Fingerprint SHA256: b4f200a08f52af099035867fed1fc9b2f0ec4c449efbcf3bdf17cd0150e2cc3 Pin SHA256: oBUBjlq8CuXPM0t8se8RoH1PidFzNvEWkVCgCR/YXo0=
Common names	*.citybyo.co.zw
Alternative names	citybyo.co.zw *.citybyo.co.zw
Serial Number	0dbd00733f0ea98043e0c9b86208f1e7
Valid from	Thu, 07 Aug 2025 00:00:00 UTC
Valid until	Fri, 07 Aug 2026 23:59:59 UTC (expires in 3 months and 13 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	RapidSSL TLS RSA CA G1 AJA: http://cacerts.rapidssl.com/RapidSSLTLSRSACAG1.crt
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL, OCSP CRL: http://odp.rapidssl.com/RapidSSLTLSRSACAG1.crl OCSP: http://status.rapidssl.com
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows



Additional Certificates (if supplied)

Certificates provided	2 (2791 bytes)
Chain issues	None

#2

Subject	RapidSSL TLS RSA CA G1 Fingerprint SHA256: 4422e963ee53cd58cc0f85cd40bf5ffec0005fd1a154535661c1c08b0ad069b Pin SHA256: E3tYowo9CiqATmKtpMLW5V+pzlq+ZoDmpXSJlXGmTo=
Valid until	Tue, 02 Nov 2027 12:24:33 UTC (expires in 1 year and 6 months)
Key	RSA 2048 bits (e 65537)
Issuer	DigiCert Global Root G2
Signature algorithm	SHA256withRSA



Certification Paths

Click here to expand

Figure 2. Certificate of www.citybyo.co.zw

The SSL Labs result shows: **DNS CAA: No (more info)** This indicates that the domain does not implement a DNS Certification Authority Authorization (CAA) record. CAA is a DNS-based security mechanism defined by the CA/Browser Forum, requiring Certificate Authorities to check whether they are authorized to issue certificates for a domain

a. Risk

The absence of a DNS Certification Authority Authorization (CAA) record exposes the domain to unrestricted certificate issuance. This means that any trusted Certificate Authority (CA) can issue an SSL/TLS certificate for the domain without explicit authorization from the domain owner.

As defined by the CA/Browser Forum, CAA records act as a control mechanism to limit which CAs are permitted to issue certificates. Without this control, the domain lacks an important layer of defense, increasing the risk of certificate mis-issuance and unauthorized trust relationships.

b. Consequences of the deficiency

The lack of DNS CAA records can lead to several security consequences:

- An attacker could potentially obtain a **fraudulent SSL/TLS certificate** for the domain from a compromised or improperly validated CA.
- This certificate could then be used to perform **Man-in-the-Middle (MITM) attacks**, allowing interception and decryption of sensitive communications, thereby undermining the guarantees provided by Transport Layer Security.
- Attackers may also create convincing phishing websites using valid HTTPS certificates, increasing the likelihood of credential theft or financial fraud.
- Additionally, without CAA reporting mechanisms, the domain owner may have no visibility into unauthorized certificate issuance attempts, delaying detection and response.

c. Proposal of the solution

To mitigate these risks, domain owners should implement **DNS CAA records** as part of their SSL/TLS security strategy.

- Domain owners should explicitly specify which Certificate Authorities are authorized to issue certificates for their domain.
- This restriction reduces the risk of fraudulent certificate issuance by ensuring that only trusted CAs can generate valid certificates.
- It is also recommended to include reporting mechanisms (**iodef**) to receive alerts about unauthorized issuance attempts.
- By implementing DNS CAA records, organizations can strengthen their security posture, enforce certificate issuance policies, and enhance overall trust in their web infrastructure.

2.3 Configuration

Configuration			
	Protocols		
	TLS 1.3		No
	TLS 1.2		Yes
	TLS 1.1		Yes
	TLS 1.0		Yes
	SSL 3	INSECURE	Yes
	SSL 2		No
	Cipher Suites		
	# TLS 1.2 (suites in server-preferred order)		
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA384 (0xc028)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK 256
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA256 (0xc027)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK 128
	TLS_ECDHE_RSA_WITH_AES_256_CBC_SHA (0xc014)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK 256
	TLS_ECDHE_RSA_WITH_AES_128_CBC_SHA (0xc013)	ECDH secp256r1 (eq. 3072 bits RSA) FS	WEAK 128
	TLS_DHE_RSA_WITH_AES_256_GCM_SHA384 (0xc09f)	DH 1024 bits FS	WEAK 256
	TLS_DHE_RSA_WITH_AES_128_GCM_SHA256 (0xc09e)	DH 1024 bits FS	WEAK 128
	TLS_RSA_WITH_AES_256_GCM_SHA384 (0x9d)		WEAK 256
	TLS_RSA_WITH_AES_128_GCM_SHA256 (0x9c)		WEAK 128
	TLS_RSA_WITH_AES_256_CBC_SHA256 (0x3d)		WEAK 256
	TLS_RSA_WITH_AES_128_CBC_SHA256 (0x3c)		WEAK 128
	TLS_RSA_WITH_AES_256_CBC_SHA (0x35)		WEAK 256
	TLS_RSA_WITH_AES_128_CBC_SHA (0x2f)		WEAK 128
	TLS_RSA_WITH_3DES_EDE_CBC_SHA (0xa)		WEAK 112
	TLS_RSA_WITH_RC4_128_SHA (0x5)		INSECURE 128
	TLS_RSA_WITH_RC4_128_MD5 (0x4)		INSECURE 128
	# TLS 1.1 (suites in server-preferred order)		
	# TLS 1.0 (suites in server-preferred order)		
	# SSL 3 (suites in server-preferred order)		

Figure 3. Configuration of www.citybyo.co.zw

All The configuration shown in the analysis reveals that the server supports outdated protocols such as **SSL 3.0**, **TLS 1.0**, and **TLS 1.1**, while **TLS 1.3 is not enabled**. Additionally, several cipher suites are marked as **WEAK or INSECURE**, including those using **RC4**, **3DES**, and CBC-based encryption, as well as weak Diffie-Hellman parameters (1024-bit).

Although some cipher suites use 128-bit encryption, which is still considered acceptable in certain contexts, the overall configuration is weakened by the presence of deprecated protocols

and insecure cryptographic algorithms. These issues significantly reduce the effectiveness of Transport Layer Security in protecting sensitive data.

a. Risk

The primary risk associated with this configuration is the increased attack surface due to legacy protocols and weak cipher suites.

- Support for outdated protocols such as SSL 3.0 and TLS 1.0 exposes the server to known cryptographic attacks (e.g., POODLE).
- The presence of weak and insecure cipher suites (e.g., RC4, 3DES, CBC mode) makes it easier for attackers to exploit vulnerabilities in encryption mechanisms.
- Weak Diffie-Hellman key exchange (1024-bit) increases susceptibility to key exchange attacks.
- As a result, an attacker with sufficient resources could potentially decrypt intercepted traffic or downgrade connections to weaker protocols, compromising secure communication.

b. Consequences of the deficiency

Data Breaches: Sensitive information such as personally identifiable information (PII), login credentials, and financial data may be exposed to unauthorized parties.

Loss of Confidentiality: Attackers can exploit weak encryption or downgrade attacks to eavesdrop on communications between clients and servers.

Man-in-the-Middle (MITM) Attacks: Weak protocols and ciphers make it easier for attackers to intercept and manipulate traffic, undermining the guarantees provided by Transport Layer Security.

Reputational Damage: Security incidents resulting from poor SSL/TLS configurations can erode user trust and damage the organization's credibility.

Legal and Regulatory Consequences: Failure to implement strong encryption may result in non-compliance with data protection regulations (e.g., GDPR), leading to fines or legal action.

Operational Disruption: Exploitation of these vulnerabilities can lead to service downtime, incident response costs, and disruption of normal business operations.

c. Proposal of the Solution

To mitigate these risks, the following measures should be implemented:

Disable legacy protocols: Completely disable SSL 3.0, TLS 1.0, and TLS 1.1, and enforce the use of **TLS 1.2** and **TLS 1.3** only.

Enable TLS 1.3: Adopt TLS 1.3 to benefit from improved security, performance, and simplified cipher suites.

Use strong cipher suites: Replace weak and insecure ciphers with modern, secure alternatives such as: AES-GCM, CHACHA20-POLY1305

Ensure Forward Secrecy: Use ECDHE-based key exchange mechanisms with strong parameters (≥ 2048 -bit or elliptic curve equivalents).

Remove insecure algorithms: Eliminate support for RC4, 3DES, and CBC-based cipher suites.

Regular security assessments: Continuously monitor and test SSL/TLS configurations using tools like Qualys SSL Labs to identify and remediate vulnerabilities.

3. Winsome Made Events

<https://winsomemadeevents.co.zw/>

- **3.1 Overall Rating**

SSL Report: winsomemadeevents.co.zw (198.175.150.250)

Assessed on: Fri, 01 May 2026 17:06:21 UTC | [Hide](#) | [Clear cache](#)

[Scan Another »](#)

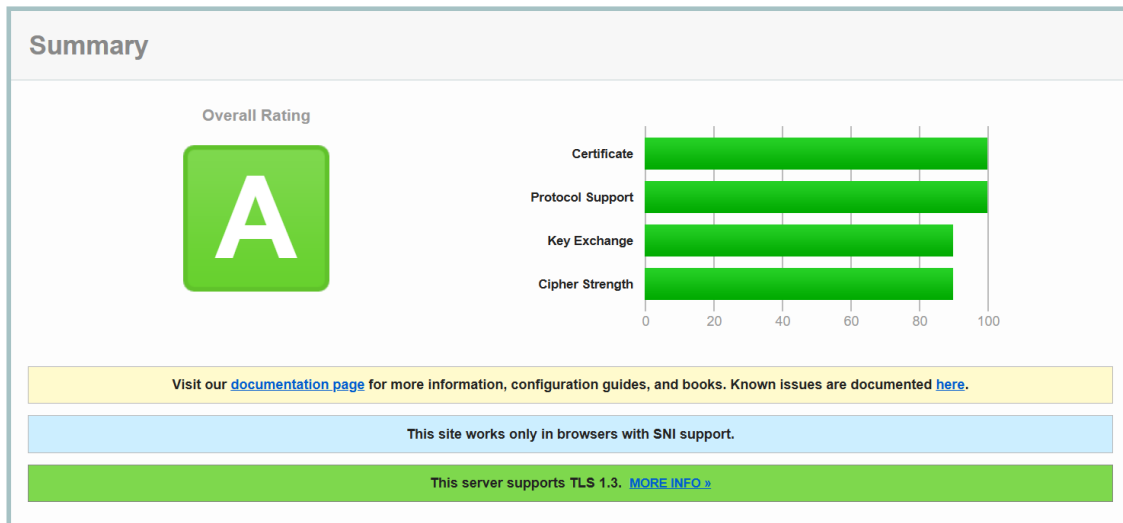


Figure 4 Overall rating www.winsomemadeevents.co.zw

The Qualys SSL Labs scan of winsomemadeevents.co.zw returned an overall grade of A. This indicates that the server's SSL/TLS configuration meets modern security standards and demonstrates good practices in certificate management, protocol support, key exchange, and cipher strength. All four rating components — Certificate, Protocol Support, Key Exchange, and Cipher Strength — scored in the high range, with Certificate and Protocol Support reaching a perfect 100, while Key Exchange and Cipher Strength both scored approximately 90.

Two notable notifications were flagged during the scan: the site requires SNI (Server Name Indication) support in the connecting browser, and the server supports TLS 1.3. These are generally positive indicators: SNI-only operation discourages legacy client connections, and TLS 1.3 support reflects an up-to-date security posture.

3.2Certificate

Certificate #1: RSA 2048 bits (SHA256withRSA)	
 Server Key and Certificate #1 	
Subject	*.winsomemadeevents.co.zw Fingerprint SHA256: 222dca9cbbb6907443bd0fbd4eebfa310137c263d9ae30ea9de8c314c4cdb43f Pin SHA256: FnEhkiF7XCQjmXHMNyStO7GcqdsQlsoljvwomw193CQ=
Common names	*.winsomemadeevents.co.zw
Alternative names	*.winsomemadeevents.co.zw winsomemadeevents.co.zw
Serial Number	060f2b19f6b6ce8481bc9197e184017699c1
Valid from	Wed, 15 Apr 2026 15:15:59 UTC
Valid until	Tue, 14 Jul 2026 15:15:58 UTC (expires in 2 months and 14 days)
Key	RSA 2048 bits (e 65537)
Weak key (Debian)	No
Issuer	R12 AIA: http://r12.i.lencr.org/
Signature algorithm	SHA256withRSA
Extended Validation	No
Certificate Transparency	Yes (certificate)
OCSP Must Staple	No
Revocation information	CRL CRL: http://r12.c.lencr.org/66.crl
Revocation status	Good (not revoked)
DNS CAA	No (more info)
Trusted	Yes Mozilla Apple Android Java Windows

Figure 5: Certificate of www.winsomemadeevents.co.zw

DNS CAA: Deficiency Analysis

The DNS CAA (Certification Authority Authorization) record is absent for the winsomemadeevents.co.zw domain. A DNS CAA record allows domain owners to restrict which Certificate Authorities (CAs) are permitted to issue SSL/TLS certificates for their domain.

- Risk: Without a DNS CAA record, any trusted CA worldwide is technically permitted to issue a certificate for winsomemadeevents.co.zw. This broadens the attack surface for certificate misissuance.
- Consequences of the deficiency: An attacker or rogue CA could potentially obtain a fraudulent certificate for the domain. Such a certificate could be used to carry out Man-in-the-Middle (MitM) attacks, intercept encrypted traffic, or steal sensitive user information.

- c. Proposal of the solution: The domain owner should implement a DNS CAA record that explicitly names Let's Encrypt (letsencrypt.org) as the only authorized CA. This can be done by adding a CAA DNS record such as: 0 issue "letsencrypt.org". This simple measure significantly reduces the risk of unauthorized certificate issuance.

Short Certificate Validity Window

The certificate was issued on 15 April 2026 and expires on 14 July 2026, giving it a total lifespan of approximately 90 days. This is consistent with Let's Encrypt's standard issuance policy. While short-lived certificates are generally considered a security best practice (they limit the exposure window of a compromised certificate), they require reliable automated renewal processes.

- d. Risk: If the certificate is not renewed before its expiration date, users will receive browser security warnings and access to the site will be effectively blocked.
- e. Consequences: An expired certificate leads to immediate loss of user trust, disruption of business operations, and potential revenue loss for the events business.
- f. Proposal of the solution: The site owner should ensure that Certbot or an equivalent ACME client is configured for automatic renewal (e.g., via a cron job or systemd timer). Renewal should be attempted at least 30 days before expiry.

- ### 3.3 Configuration

Configuration		
	Protocols	
	TLS 1.3	Yes
	TLS 1.2	Yes*
	TLS 1.1	No
	TLS 1.0	No
	SSL 3	No
	SSL 2	No
	(*) Experimental: Server negotiated using No-SNI	
	Cipher Suites	
	# TLS 1.3 (server has no preference)	
	TLS_AES_128_GCM_SHA256 (0x1301) ECDH x25519 (eq. 3072 bits RSA) FS	128
	TLS_AES_256_GCM_SHA384 (0x1302) ECDH x25519 (eq. 3072 bits RSA) FS	256
	TLS_CHACHA20_POLY1305_SHA256 (0x1303) ECDH x25519 (eq. 3072 bits RSA) FS	256
	# TLS 1.2 (suites in server-preferred order)	
	TLS_ECDHE_RSA_WITH_AES_128_GCM_SHA256 (0xc02f) ECDH x25519 (eq. 3072 bits RSA) FS	128
	TLS_ECDHE_RSA_WITH_AES_256_GCM_SHA384 (0xc030) ECDH x25519 (eq. 3072 bits RSA) FS	256
	TLS_ECDHE_RSA_WITH_CHACHA20_POLY1305_SHA256 (0xcca8) ECDH x25519 (eq. 3072 bits RSA) FS	256

Figure 6 :Configuration of www.winsomemadeevents.co.zw

All supported cipher suites provide Forward Secrecy (FS), meaning that the compromise of the server's long-term private key would not expose previously recorded session traffic. The use of ECDH x25519 for key exchange (equivalent to 3072-bit RSA) provides strong key exchange security. No weak, NULL, EXPORT, RC4, or DES cipher suites are present.

TLS 1.2 No-SNI Negotiation (Minor Advisory)

The SSL Labs report marks TLS 1.2 with an asterisk (*) indicating it was negotiated experimentally without SNI (Server Name Indication). This means that clients that do not send the SNI extension during the TLS handshake may still be able to connect using TLS 1.2, potentially to a default or fallback certificate.

- g. Risk: Legacy clients (e.g., very old browsers or embedded systems) that lack SNI support may connect through a different, possibly less secure, certificate path.

- h. Consequences: Users on legacy clients may encounter unexpected certificate warnings or may unknowingly connect to a fallback virtual host. This is also noted by SSL Labs with a separate blue notification: “This site works only in browsers with SNI support.”
- i. Proposal of the solution: If the server hosts multiple virtual hosts on the same IP address, ensure that the default virtual host also presents a valid and trusted certificate. Alternatively, enforce SNI-only operation and document that legacy non-SNI clients are not supported, consistent with the stated site notice.

● **Summary and Recommendations**

Overall, winsomemadeevents.co.zw demonstrates a solid SSL/TLS security posture, earning an A rating from Qualys SSL Labs. The server correctly disables all deprecated protocols (TLS 1.0, 1.1, SSL 2/3), supports TLS 1.3, uses strong cipher suites with forward secrecy, and holds a valid, publicly trusted certificate issued by Let’s Encrypt. Certificate Transparency logging is active, and no revocation issues were found.

The following improvements are recommended to further strengthen the security configuration:

1. Add a DNS CAA record to restrict certificate issuance to Let’s Encrypt only, reducing the risk of fraudulent certificate issuance by rogue CAs.
2. Ensure automated certificate renewal is configured and monitored, given the 90-day Let’s Encrypt certificate lifecycle.
3. Enable OCSP Must-Staple on the certificate to ensure the browser always receives fresh revocation information without additional round-trip OCSP queries.
4. Consider enabling HTTP Strict Transport Security (HSTS) with a long max-age and submitting the domain to the HSTS preload list to prevent downgrade attacks entirely.
5. Review the No-SNI TLS 1.2 fallback behavior and ensure the default virtual host presents a trusted certificate, or document that non-SNI clients are explicitly unsupported.

Implementing these recommendations would likely elevate the site's rating from A to A+, reflecting best-in-class SSL/TLS security configuration.

References:

<https://www.ssllabs.com/ssltest/index.html>

https://blog.qualys.com/product-tech/2017/03/13/caa-mandated-by-browser-forum?_ga=2.142338546.1305110633.1777034279-1012637642.1774370127